

1. Purpose Password Protection Policy

This Password Protection Policy establishes standards and guidelines for the creation, management, protection, and periodic assessment of passwords across all Zenith Orbital Systems (ZOS) systems and accounts. Compromised credentials remain the single leading cause of data breaches worldwide. According to the Verizon 2025 Data Breach Investigations Report, stolen, weak, or reused passwords are involved in 88% of basic web application attacks and 22% of all breaches. In 2025 alone, over 5 billion accounts were compromised globally.

This policy provides a clear, enforceable framework that enables ZOS personnel to create strong credentials, reduces the burden of password management through approved tooling, mandates multi-factor authentication, and establishes screening controls that prevent the use of known compromised passwords. By aligning with NIST SP 800-63B, Microsoft's modern authentication guidance, and current industry best practices, this policy protects ZOS mission assets without imposing unnecessary friction on users.

2. Scope

This policy applies to all employees, contractors, consultants, temporary workers, and third-party personnel with access to any ZOS system, account, or resource. It covers all password-protected accounts and credentials including:

- User-level accounts on all ZOS systems and platforms
- System-level and service accounts, including automated processes and scripts
- Web application and SaaS platform accounts
- Email and collaboration platform accounts
- Privileged and administrative accounts
- VPN, remote access, and network device accounts
- Voicemail, screen saver, and local device protection
- API keys, tokens, and other programmatic credentials

Compliance with this policy is mandatory for all in-scope individuals. Deviations require written approval through the exception process defined in Section 12.

3. Principle Statement

Password security at ZOS is managed on the principle that length is more important than complexity, usability supports compliance, and no password policy is complete without multi-factor authentication. Forcing users into rigid, frequently-changing complexity requirements has been shown by NIST and Microsoft research to produce weaker security outcomes because users respond with predictable patterns, minor variations, and credential reuse.

This policy reflects the modern consensus: require long passphrases over short complex strings, eliminate arbitrary expiration cycles, screen all passwords against known breach databases, mandate MFA on all sensitive systems, and use approved password managers to eliminate the human memory burden that drives poor credential hygiene.

4. Senior Management Commitment

ZOS senior leadership is fully committed to the implementation and enforcement of this Password Protection Policy. We recognize that credential compromise is the most common entry point for attackers and that protecting ZOS accounts and orbital mission systems requires both strong technical controls and a user-friendly approach that personnel will actually follow.

Senior management commits to providing approved password manager tools, MFA infrastructure, and training resources necessary to support compliance with this policy. This policy will be reviewed annually and updated to reflect changes in NIST guidance, industry standards, and the threat environment.

Signed: _____ **Date:** _____

Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems

5. Industry Benchmarks and Current Trends (2026)

5.1 Length Over Complexity

The industry has decisively moved away from arbitrary complexity requirements toward length-based standards. In 2026, a standard consumer-grade GPU can crack an 8-character password in under 12 minutes regardless of its complexity. A 16-character passphrase composed of unrelated common words is exponentially harder to crack and far easier for users to remember. NIST, Microsoft, and the UK's National Cyber Security Centre all now recommend this approach.

5.2 Elimination of Mandatory Periodic Rotation

Mandatory 30, 60, or 90-day password rotation cycles are now recognized by NIST and Microsoft as counterproductive. Research consistently shows that users respond to forced rotation by making minimal changes to existing passwords, which provides no real security benefit. Both NIST SP 800-63B and Microsoft's current guidance recommend that passwords only be changed upon evidence or suspicion of compromise, not on a calendar schedule. This policy adopts that standard for standard user accounts while retaining annual rotation requirements for ZOS privileged accounts.

5.3 Breached Password Screening

Modern authentication systems now integrate with breach databases such as HaveIBeenPwned, which contains over 10 billion compromised credentials, to screen passwords at creation and login time. Specops Software's 2026 research found that predictable behavior such as uppercase first letters, numbers at the end, and common substitutions remains the dominant pattern in breached corporate credentials,

confirming that composition rules without breach screening provide a false sense of security.

5.4 MFA as the Primary Defense Layer

Multi-factor authentication has become the single most impactful control in the credential security stack. Microsoft's data shows that MFA prevents over 99.9% of credential-based account compromises. In 2026, the standard is moving toward number-matching MFA and phishing-resistant MFA such as FIDO2 hardware keys and passkeys, which eliminate the push notification attack surface entirely. ZOS targets FIDO2 authentication for all privileged roles per the AZTOF Identity and Access Governance domain.

5.5 Password Managers as Organizational Infrastructure

Enterprise-grade password managers such as 1Password Business and Bitwarden Teams have evolved from personal productivity tools into organizational security infrastructure. They generate cryptographically random passwords, eliminate credential reuse across systems, store credentials in encrypted vaults with access controls, and provide administrative visibility into credential health across the organization.

6. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; annual review; exception approvals; violation escalation; compliance reporting
Systems Administrators	Implement technical controls; configure account lockout; operate breach screening tools; enforce MFA enrollment
Security Analysts	Conduct quarterly password audits; review lockout logs; track policy compliance metrics
All ZOS Employees and Contractors	Create compliant passwords; enroll in MFA; use approved password manager; report suspected compromise immediately
New Hires	Complete password security training during onboarding; enroll in MFA on first day of access

7. Policy Controls and Standards

7.1 Password Length and Format

Control ID	Requirement
------------	-------------

PWD-01	Minimum password length is 16 characters. Systems must support passwords up to at least 64 characters to enable passphrase use.
PWD-02	Passphrases composed of multiple unrelated words are the preferred password format. Examples include metal-lemon-49-blanket or sunrise-cable-forest-rain. Predictable patterns such as ZOS2026 or seasonal passwords like Spring2026 are prohibited.
PWD-03	Passwords must not be reused across ZOS accounts. Users must not reuse any of their last 10 passwords on any given system.
PWD-04	Passwords must never be shared with any other person, including managers, IT staff, or help desk personnel. ZOS IT staff will never ask for a user's password.

7.2 Password Screening and Breach Detection

Control ID	Requirement
PWD-05	All new passwords must be screened against known-compromised credential databases at the time of creation. Passwords found in breach databases must be rejected regardless of length or complexity. HaveIBeenPwned API or equivalent is required.
PWD-06	The InfoSec Team will conduct periodic password audits using approved cracking tools to identify weak or guessable passwords on ZOS systems. Users whose passwords are identified as weak will be required to change them immediately.

7.3 Password Expiration and Rotation

Control ID	Requirement
PWD-07	Standard user account passwords do not require periodic rotation unless compromise is known or suspected. Password changes are required immediately upon any confirmed or suspected account compromise.

PWD-08	Privileged account passwords must be rotated at minimum annually. Service account passwords must be rotated whenever the responsible administrator leaves the organization or their role changes.
---------------	---

7.4 Multi-Factor Authentication (MFA)

Control ID	Requirement
PWD-09	MFA is mandatory for all ZOS accounts accessing email, collaboration platforms, VPN and remote access, cloud services, administrative and privileged accounts, and any system containing sensitive or regulated data.
PWD-10	Approved MFA methods in order of preference: FIDO2 hardware keys or passkeys (required for all privileged roles); authenticator app with number matching (Okta Verify, Microsoft Authenticator); push notification with number matching. SMS-based MFA is not permitted for any ZOS account.

7.5 Password Management Tools

Control ID	Requirement
PWD-11	All ZOS personnel must use only approved enterprise password manager tools for storing organizational credentials. Personal consumer-grade password managers are not permitted for organizational credentials. The approved ZOS password manager is provisioned and managed by the IT Security Team.
PWD-12	Passwords must never be stored in plaintext in documents, spreadsheets, email, messaging apps, code repositories, or any other unencrypted format. All stored passwords must use approved hashing algorithms (bcrypt, Argon2id, or PBKDF2 with minimum recommended iterations). This control protects credentials even if the underlying database is breached.

7.6 Account Lockout

Control ID	Requirement
-------------------	-------------

PWD-13	Account lockout must be enforced after no more than 10 consecutive failed login attempts. Lockout duration must be at minimum 15 minutes or until reset by IT. Lockout events must be logged and reviewed for patterns indicating brute force attacks.
---------------	--

8. Legal and Regulatory Obligations

Framework	Relevance to This Policy
NIST SP 800-63B	Primary technical standard for password length, complexity, screening, expiration, and MFA requirements
NIST CSF 2.0	Protect (PR.AC) function: Identity management, authentication, and access control
CIS Controls v8	Control 5 (Account Management), Control 6 (Access Control Management): password and MFA requirements
PCI DSS v4.0	Requirements 8.2 and 8.3: minimum 12-character passwords, MFA for admin and remote access, account lockout after 10 attempts
ISO/IEC 27001:2022	Annex A.9 (Access Control): authentication management, password policies, privileged access
HIPAA Security Rule	Administrative and technical safeguards requiring unique user identification and authentication controls
GDPR and TDP SA	Appropriate technical measures to protect personal data, including strong authentication for systems processing personal information

9. Training and Awareness

All ZOS personnel must receive password security training appropriate to their role:

- All Employees and Contractors: Annual training on passphrase creation, the approved password manager, MFA enrollment and use, recognizing phishing and credential theft attempts, and the procedure for reporting suspected account compromise.
- System Administrators: Annual training on implementing and enforcing technical password controls in Active Directory and all platforms, configuring account lockout policies, and operating breach screening tools.

- New Hires: Password security training must be completed during onboarding, prior to receiving access credentials. MFA enrollment must be completed on the first day of access.

Training completion records are maintained by the IT Security Team and retained for a minimum of three years.

10. Compliance Measurement

Activity	Controls Assessed / Frequency
Password audit using approved cracking tools	PWD-05, PWD-06 / Quarterly
Breached password screening report review	PWD-05 / Monthly (automated)
MFA enrollment verification	PWD-09, PWD-10 / Monthly
Account lockout event log review	PWD-13 / Weekly
Privileged account password rotation audit	PWD-08 / Annual
Password manager adoption report	PWD-11 / Quarterly
Full policy compliance assessment	All PWD controls / Annual

Results are documented and reported to the IT Security Manager. Material non-compliance findings are escalated to senior IT leadership within 5 business days.

11. Exception Management

Legacy systems or operational constraints may occasionally prevent full compliance with specific controls. All exceptions must follow this process:

- The requesting party submits a written exception request to the IT Security Manager documenting the specific control affected, the technical or business justification, proposed compensating controls, and the requested duration (maximum 90 days).
- Exceptions to PWD-09 (MFA requirement) require both IT Security Manager and senior IT leadership approval given the elevated risk of unauthenticated access.

- All approved exceptions are logged in the exception register with compensating controls, approving authority, and expiration date.
- The exception register is reviewed monthly. Expired exceptions not formally renewed are treated as policy violations.

12. Policy Sanctions

Non-compliance with this policy will result in disciplinary action consistent with ZOS human resources policies. Sanctions are applied consistently and proportionally:

Severity	Consequence
Minor / First Offense	Formal written warning; mandatory remedial training; re-acknowledgment of policy required within 10 business days
Moderate / Negligent	Formal written warning; mandatory remedial training; review with IT Security Manager; potential temporary suspension of elevated access
Severe / Willful Violation	Immediate review of system access; HR investigation; potential removal of administrative access; potential termination of employment or contract
Criminal / Illegal Activity	All above consequences plus referral to law enforcement; legal action under applicable federal and state statutes

13. Sources and References

- NIST SP 800-63B Digital Identity Guidelines. <https://pages.nist.gov/800-63-3/sp800-63b.html>
- NIST Cybersecurity Framework 2.0. <https://www.nist.gov/cyberframework>
- CIS Controls v8. <https://www.cisecurity.org/controls/v8>
- PCI DSS v4.0. https://www.pcisecuritystandards.org/document_library/
- ISO/IEC 27001:2022. <https://www.iso.org/standard/82875.html>
- CISA Known Exploited Vulnerabilities Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- Verizon 2025 Data Breach Investigations Report. <https://www.verizon.com/business/resources/reports/dbir/>
- Microsoft Password Guidance. <https://www.microsoft.com/en-us/research/publication/password-guidance/>
- SANS Institute Security Policy Templates. <https://www.sans.org/information-security-policy/>